

NDATrace: Does Additional AI Complexity Earn Its Place?

A business case for bounded, evidence-grounded NDA review assistance, tested through controlled engineering experiments.

Ubaidulla Asmitha · Group B

1 Business problem and contribution

Tina, a legal-operations analyst, checks vendor NDAs against standard confidentiality requirements before counsel approves them. Obligations may be paraphrased, qualified by exceptions or spread across clauses, so keyword search can locate language without resolving its meaning. Commercial tools such as Ironclad, Luminance and Kira already support AI-assisted review; I test how to treat incomplete or conflicting evidence. NDATrace classifies each requirement as Entailment, Contradiction or NotMentioned and quotes evidence for Tina to check before recording a decision. It replaces an unaided first reading with verification of specific findings, not legal judgment. Survey evidence [1] gives workload context, not proof of savings from this prototype.

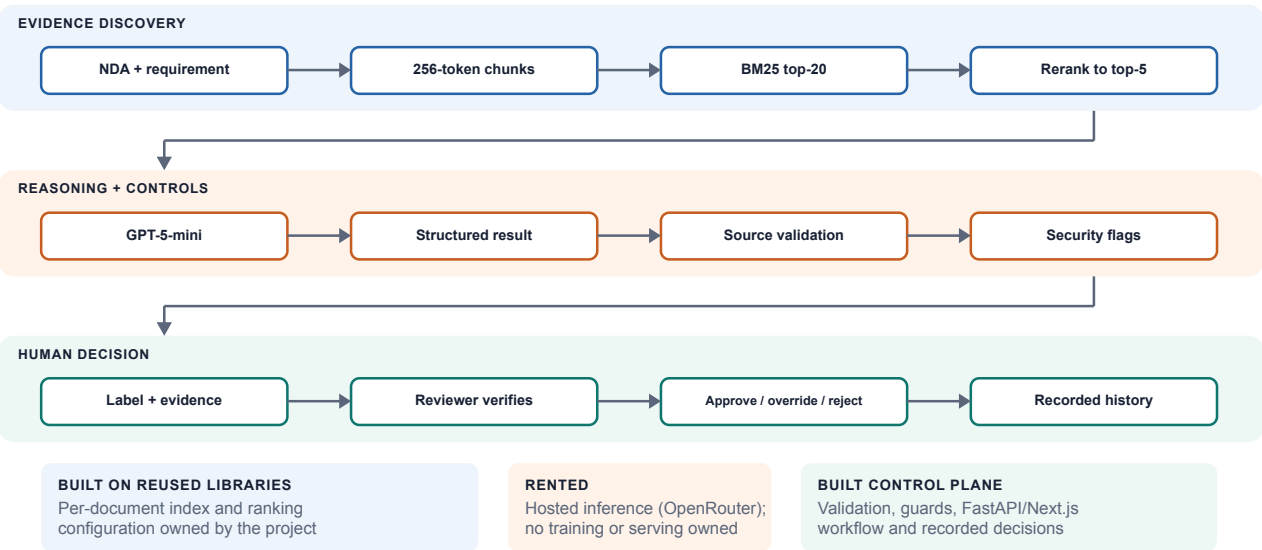
I tested whether that assistance merits its AI complexity rather than assuming it does.

2 Solution and design decisions

I compared three approaches: a non-AI keyword-rule baseline, a full-context language model (FULL) that reads the whole NDA, and retrieval-augmented generation (RAG), which retrieves selected clauses before interpretation. The implemented design separates semantic judgment from predictable controls (Figure 1, Table 1). Project-owned code chunks, retrieves, checks that cited quotations exist in the source, applies limits and security flags, and records reviewer decisions. Only interpretation is rented through one GPT-5-mini call. Renting avoids training and hosting costs but adds provider dependence; controlling retrieval bounds model context but makes an omitted clause a new failure mode. Source validation checks provenance, not whether a quotation supports the conclusion.

Implemented NDATrace review path

Deterministic evidence controls around one bounded, rented semantic decision



Deliberately absent: agent loop, confidence gate, automatic approval, FULL-context fallback and any gold-aware runtime logic.

Figure 1. Implemented architecture. Frozen runtime path, grouped by what is deterministic and owned versus the one rented semantic call; rejected components are listed as absent.

Table 1. Build versus rent.

Layer	Decision	Commercial or engineering reason
Model	Rent GPT-5-mini	Strongest measured reasoning; no training or serving burden
Compute	Rent hosted API	Sub-cent pay-per-call cost; local models kept only as comparators
Data	Reuse ContractNLI [2]	Public gold labels and evidence spans allow controlled evaluation
Retrieval	Build on reused libraries	Own chunking, ranking and context size
Orchestration and evaluation	Build	One bounded call; split discipline, paired tests, evidence evaluator
Serving and governance	Build	FastAPI and Next.js review interface with evidence display, persisted reviewer decisions, guards and limits

3 Experimental justification

Table 2. Architecture ladder. Each rung is a separate question, tested against the rung below it; populations differ by rung (noted per row).

Rung	Question	Risk-sensitive recall	Gain over Rule	Decision
Rule (A0)	Can deterministic rules solve enough of the problem to avoid an LLM? (TEST n=2,091)	53.6%	baseline	Non-AI baseline: cheap and fast, insufficient semantic coverage
FULL (A1)	What happens when the model sees the entire NDA? (TEST n=2,091)	69.1%	+15.4	Quality reference: strongest measured Joint correctness; not the prototype runtime
RAG (A2)	Can bounded retrieval keep quality while shrinking the evidence path? (TEST n=2,091)	70.3%	+16.6 (vs Rule)	Adopted as prototype runtime for bounded context and lower inference cost
Agent (A3)	Can dynamic investigation recover the cases RAG still misses? (TRAIN n=150)	—	—	Rejected: 0% useful recovery across three evaluations (Figure 5)

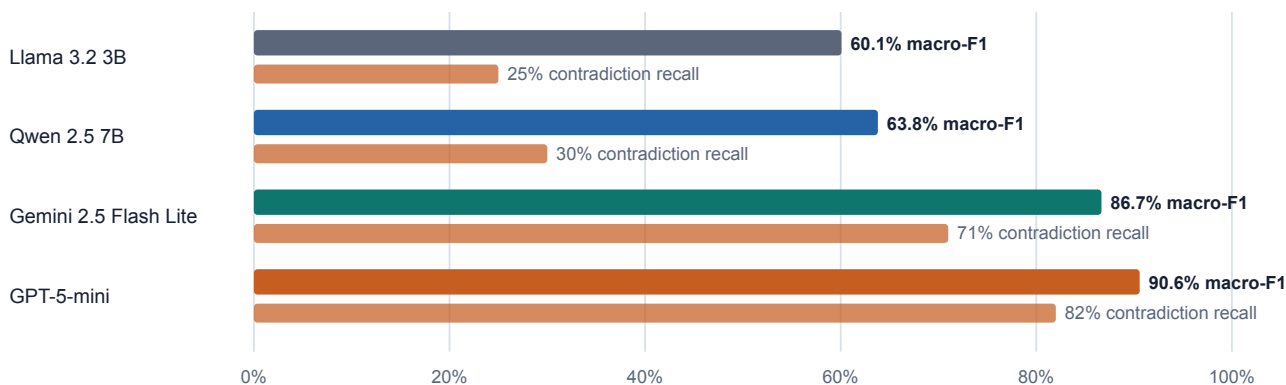
I began with a rule-based keyword baseline: the cheapest way to test whether AI adds value. Before building retrieval, I ran an oracle experiment giving four models the gold evidence directly. GPT-5-mini interpreted the evidence substantially better than the tested local alternatives, particularly for contradictions (Figure 2). Given the whole NDA on the official TEST set, the local model also fell below the keyword rules. I then tested prompting, chunking, retrieval and reranking before comparing complete architectures. These stages answered different questions on separate populations and are not one pooled benchmark (Table 3).

Table 3. Experimental decisions (populations never pooled).

Stage	Alternatives (population)	Decisive evidence	Decision
Model	Four models, gold evidence (TRAIN n=300 each)	GPT-5-mini macro-F1 0.906 vs Qwen 0.638	Rent GPT-5-mini
Prompt	Three prompt styles; GPT variant re-tested (TRAIN n=150)	Minimal prompt led; variant's gain reversed on re-test	Keep minimal prompt
Retrieval	Chunking, BM25/dense/hybrid, reranker (TRAIN n=4,371)	BM25 = dense after reranking (92.2% Recall@5)	Clause-256, BM25 top-20, rerank to 5
Context expansion	Top-5 vs top-11 (TRAIN n=150)	+4.0 Joint points (p=0.263); input +64%	Keep top-5
Routing	Three review policies (DEV n=138)	Best: 51.4% reviewed (target ≤40%), 10.4% residual error (target <10%)	Review every case
Security	20 attack pairs; OWASP LLM Top 10	FULL-context arm: 4/11 injections succeeded. RAG path (separate check): 1/7 attack cases succeeded; poisoned clause ranked first 8/8. Guard flags 4/11 of the FULL-context attack variants. 2 OWASP fails → 0 after fixes	Quarantine flag plus mandatory review

Oracle evidence isolates model reasoning

Balanced TRAIN_ORACLE_v1, n=300 per model; gold evidence supplied directly



Decision: rent GPT-5-mini. With perfect evidence, local models still missed most contradictions.

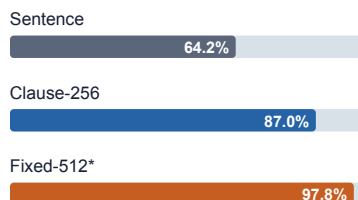
Figure 2. Oracle model selection (TRAIN, n=300 per model, gold evidence).

Experiments also showed where complexity was unnecessary. Very large chunks inflated recall by approaching whole-document coverage, not by focusing evidence. Hybrid retrieval led before reranking, but BM25 and dense candidates reached the same Recall@5 afterward (Figure 3). I chose BM25 with reranking because an embedding index showed no final-stage benefit.

Retrieval complexity had to earn its place

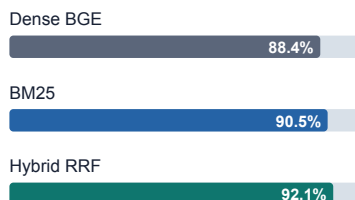
Evidence-bearing TRAIN cases, n=4,371; retrieval diagnostics, not classification accuracy

A. Chunk boundary (Recall@5)



*Near-whole-document chunks saturate recall; MRR fell to 0.183 and context doubled.

B. First-stage Recall@5



Before reranking, hybrid led; this was not the decisive comparison.

C. After identical reranking



Only 1 of 4,371 cases differed, so BM25 avoids an unearned embedding index.

DECISION Clause-256 → BM25 top-20 → cross-encoder top-5. Reranking dense candidates: Recall@5 88.4% → 92.2% (231 recovered, 72 regressed). Candidate recall and final evidence quality are distinct stages; top-5 bounds what the classifier sees.

Figure 3. Retrieval optimisation (TRAIN, n=4,371).

4 Measured results and trade-offs

The rule-based system remains the project's non-AI baseline and answers the first question: did adding semantic AI help where keyword matching cannot interpret reliably? Both LLM approaches improved substantially on rules (Table 3, Table 4); RAG's measured gain over Rule is +16.6 risk-sensitive-recall points. FULL remains the stronger quality-reference configuration on

Joint correctness, while RAG is the selected interactive runtime. Joint correctness matters here because a correct label backed by the wrong clause is not a dependable review finding. Risk-sensitive recall is the macro-average of Contradiction and NotMentioned recall, so Contradiction counts equally; a pooled recall would be dominated by NotMentioned, where the rule system scores highest by defaulting to that label.

Table 4. Official architecture comparison (official TEST, n=2,091). Rule is the non-AI baseline. Risk-sensitive recall is macro-averaged. Differences use unrounded recalls. An always-Entailment majority guess scores 46.3% accuracy.

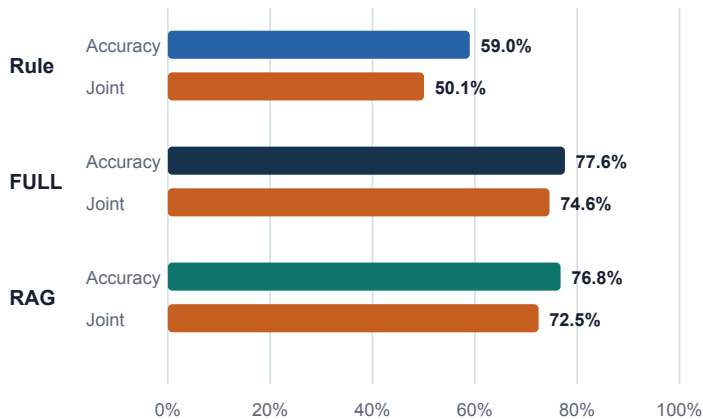
Metric	Rule-based	FULL	RAG
Quality			
Accuracy	59.0%	77.6%	76.8%
Macro-F1	0.479	0.727	0.723
Joint correctness (label + evidence)	50.1%	74.6%	72.5%
Risk-sensitive recall (Contradiction/NotMentioned mean)	53.6%	69.1%	70.3%
Separate comparison: gain over Rule non-AI baseline	baseline	+15.4	+16.6
Paired McNemar p vs FULL: accuracy / Joint	—	—	0.217 / 0.0047
Entailment / NotMentioned recall	39.3 / 90.5%	92.0 / 62.7%	89.3 / 63.2%
Contradiction recall, n=220 (95% Wilson CI)	16.8%, 37/220 [12.5, 22.3]	75.5%, 166/220 [69.4, 80.7]	77.3%, 170/220 [71.3, 82.3]
Efficiency			
Mean input tokens per case	—	2,279	1,131
Mean output tokens per case	—	729	701
Measured API cost per case	\$0 (local)	\$0.00202	\$0.00168
Mean latency	0.09 ms	7.31 s	7.14 s

RAG's measured benefit was lower inference cost, not better evidence quality. Its accuracy difference from FULL was not statistically significant, while FULL's Joint advantage was (McNemar $p=0.0047$). In the base cost-to-serve scenario FULL is also cheaper end to end (Section 6). Keeping RAG is therefore an engineering decision, not a measured win: retrieval caps what the model sees and does not require the whole contract to fit in context, properties I did not test on longer contracts. Reviewer-time measurements and longer-contract tests must decide which architecture is economically preferable; this is not a deployment recommendation.

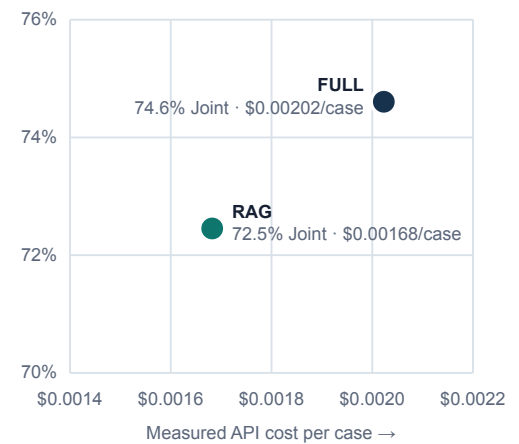
Quality and inference-cost trade-off

Official ContractNLI TEST, identical 2,091-case population

A. Label accuracy vs evidence-grounded Joint



B. Measured inference frontier



Joint = correct label plus sufficient annotated-evidence overlap; not a legal-adequacy judgment. Rule compute is unpriced.

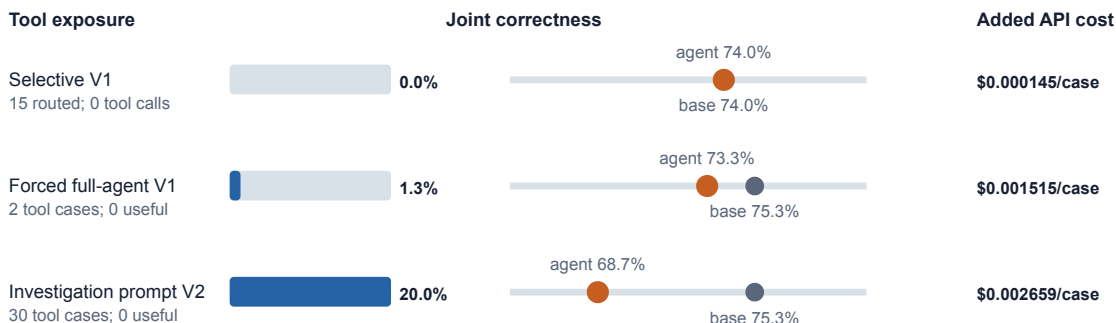
Figure 4. Architecture quality versus cost (official TEST, n=2,091).

5 Rejected complexity and residual failures

Some failures appeared recoverable through a second search, so I tested three capped agent variants (Figure 5). The selective agent made no tool calls; prompting it to investigate increased tool use without producing useful recoveries. Automatic routing, my stand-in for abstention, also missed its targets: rule-model disagreement would escalate 51.4% of cases to catch 82.5% of failures, exceeding the 40% ceiling, and misses errors on which both systems agree. I therefore rejected both additions: the prototype does not abstain automatically, and human review is mandatory.

More agent activity did not create more value

Three TRAIN evaluations on the same 150-case population; matched controls retained within each evaluator



DECISION Reject the tested agent. Prompt V2 proved inactivity was partly fixable; zero useful recoveries proved activity was not benefit. "Useful" is an outcome-associated proxy, not a causal estimate; these TRAIN results do not rule out different tools or tasks.

Figure 5. Agent investigation (TRAIN, n=150; evaluators not pooled; the selective trial used an earlier evaluator).

Most residual failures are interpretive, not retrieval gaps, with only a small share retrieval-limited (Figure 6). The largest single pattern is over-inference: most of RAG's label errors (330 of 486) are NotMentioned requirements judged supported or contradicted, as FULL's also are, which gives a reviewer false assurance. Both architectures also sometimes misread negations or exceptions despite receiving the right text. RAG sometimes omitted relevant spans or failed to cite retrieved evidence; FULL could be distracted by irrelevant permissive language elsewhere. More context or agent activity alone therefore does not address the largest observed problem: interpreting the supplied clauses correctly.

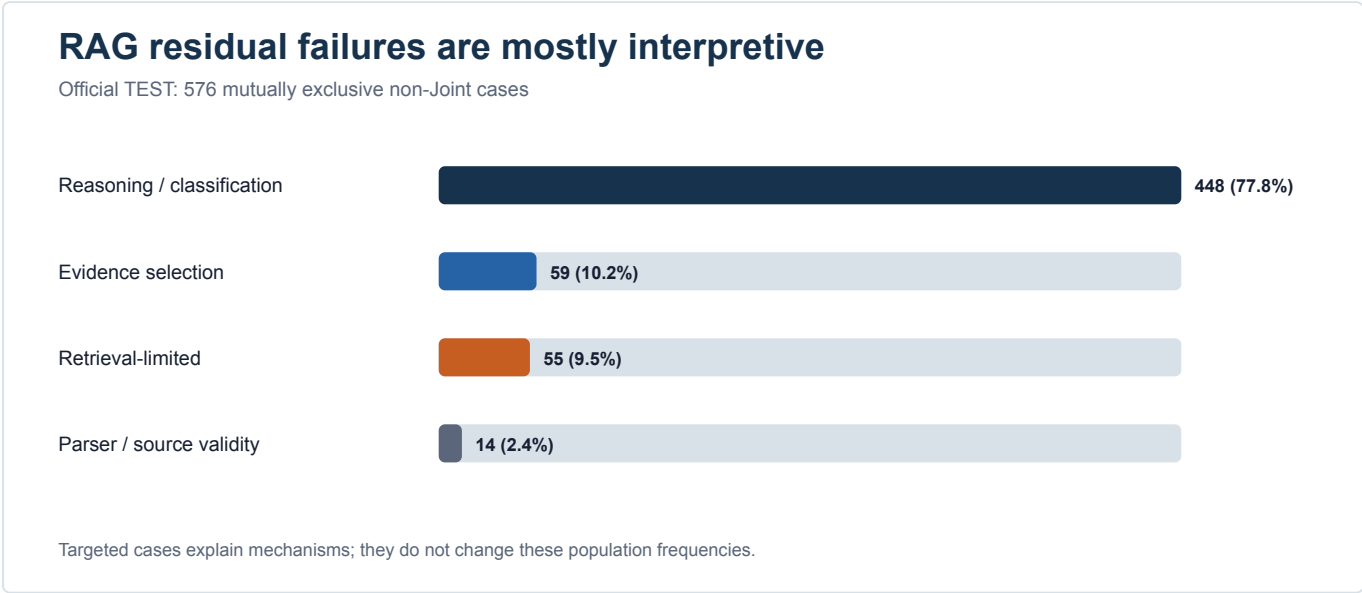


Figure 6. Official failure analysis (all non-Joint RAG cases, official TEST).

6 Business feasibility and risk

A cheaper API call does not necessarily mean a cheaper review (Table 5, Figure 7). Every finding still requires human verification, errors may trigger additional investigation, and the labor figures are assumptions, not measured savings. In the base scenario, FULL's higher evidence correctness more than offsets RAG's lower inference price; without a timed reviewer study and operational costs, I cannot claim a return on investment.

Table 5. Cost-to-serve assumptions (1,000 requirement reviews). Totals appear in Figure 7 as formula outputs.

Component	Value used	Evidence status
Inference	FULL \$0.00202, RAG \$0.00168 per case; Rule \$0 API	Measured on official TEST
Mandatory verification	5 min at \$40/h = \$3.33 per case, every architecture	Assumption
Additional investigation	10 min × non-Joint rate; varied 0–20 min	Hypothetical proxy, not observed
Fixed operations	Hosting, monitoring, support, security	Excluded: unmeasured, not zero

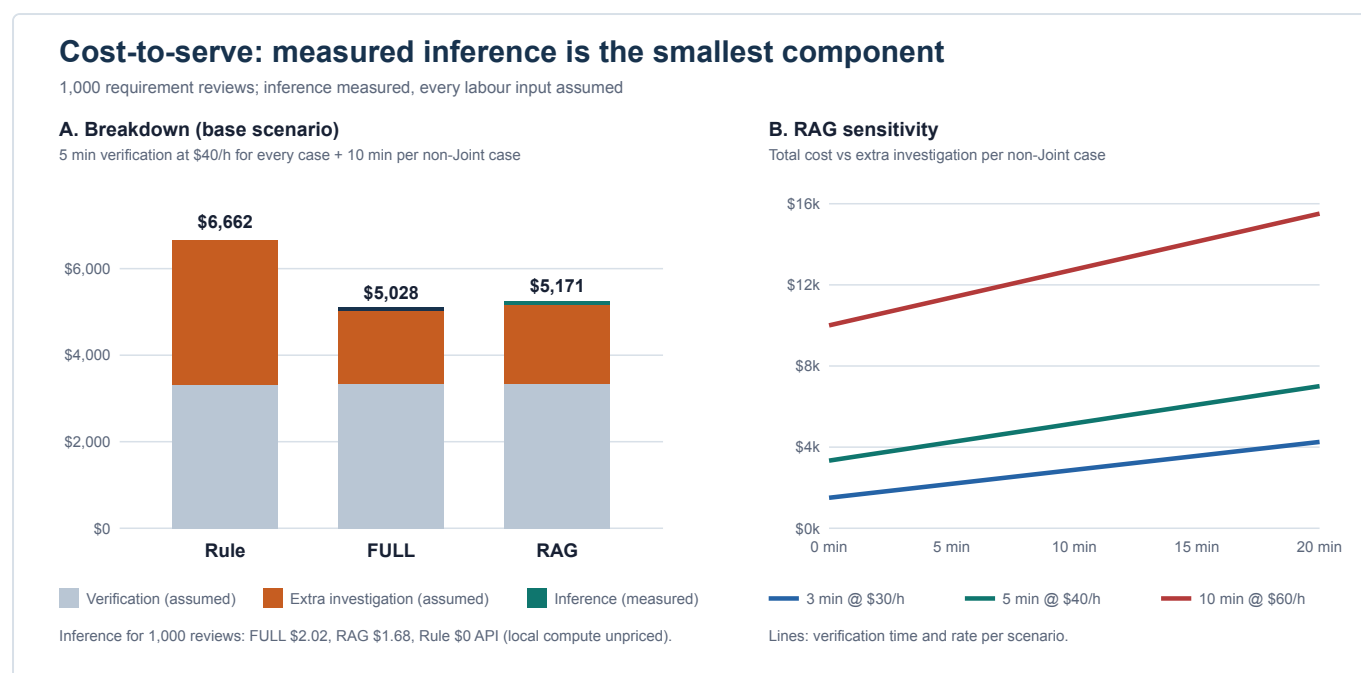


Figure 7. Cost-to-serve breakdown and sensitivity. Inference is measured; all labour inputs are assumptions; fixed costs excluded.

RAG's savings were smaller than its context reduction suggested: at the recorded GPT-5-mini prices (\$0.25 input, \$2 output per million tokens; OpenRouter, checked 22 September 2026), output tokens cost eight times as much per token as input and neither architecture reduced them, so halving input tokens did not come close to halving inference cost (Table 5).

Security results (Table 6) come from two populations that should not be merged. The paired attack experiment tested the FULL-context arm: Joint correctness fell from 85% to 75% (20 pairs). A separate check of the selected RAG path used seven synthetic attack cases; one succeeded, a request to return the whole context as evidence. Both samples are small and descriptive. In the FULL-context experiment, one injected passage was returned as evidence and passed source validation because the text existed in the document: provenance does not establish trustworthiness. Cost limits and an injection guard addressed specific risks; detection remained incomplete. Human review provides a decision point, not a proven defense against adversarial text or ordinary, plausible but unsupported findings.

Table 6. OWASP Top 10 for LLM Applications, 2026 edition [3]: before and after remediation. Baseline assessment versus the one targeted remediation pass; only two categories changed.

Category	Before remediation	After remediation
LLM01 Prompt Injection	FAIL (RAG path: 1 of 7 cases)	PARTIAL (guard flagged 4/11 FULL-context attack variants, below the pre-declared ≥8/11 bar)
LLM02 Sensitive Information Disclosure	PARTIAL	PARTIAL (no auth added, not remediated this pass)
LLM03 Excessive Agency	PASS	PASS (unchanged)
LLM04 Supply Chain	PARTIAL (38 known CVEs)	PARTIAL (34 known CVEs, 2 low-risk patched)
LLM05 Data and Model Poisoning	PARTIAL	PARTIAL (unchanged, not in scope this pass)
LLM06 Unbounded Consumption	FAIL	PASS (real cost/rate/length limits now enforced)
LLM07 Misinformation	PARTIAL	PARTIAL (unchanged; reframes the measured TEST error rate)
LLM08 Hidden Context Exposure	PASS	PASS (unchanged)
LLM09 Vector and Embedding Weaknesses	PARTIAL	PARTIAL (unchanged)
LLM10 Improper Output Handling	PASS	PASS (unchanged)
Totals	3 PASS / 5 PARTIAL / 2 FAIL	4 PASS / 6 PARTIAL / 0 FAIL

7 Critical evaluation and future direction

Evaluation critique

This evaluation supports controlled architectural comparisons, not autonomous legal decisions. Historical access to TEST prevents claiming perfect blindness, though final-protocol choices were not tuned on TEST outcomes. Separately, ContractNLI's public agreements and fixed requirements may not represent longer confidential NDAs. Finally, Joint correctness checks overlap with annotated spans, not whether a finding is legally adequate.

Difficulties overcome

A \$10 OpenRouter budget was the binding constraint. The plan was a hosted subsample alongside local-model coverage; I instead completed paired FULL and RAG runs over the full TEST population, consuming most of the key's remaining budget. The record does not show why I departed from the plan, so I report the choice without a justification. Calibration also caught two evaluation risks, exact-character quotation matching that unfairly rejected formatting variants

and a local-server context setting that silently truncated long inputs; correcting both avoided distorted comparisons.

Rough edges

The prototype still misinterprets some exception clauses and misses parts of multi-span evidence. Stored results lack authentication and dependencies have known vulnerabilities, barriers to handling confidential NDAs.

Future path

Next, I would test exception reasoning on an independently labeled set, measure retrieval coverage separately from citation completeness, and evaluate longer expert-labeled contracts. Authentication, access control, further adversarial testing and monitoring are prerequisites for deployment.

8 Conclusion

The rule-based non-AI baseline established that semantic AI adds substantial value to this task: RAG gained +16.6 risk-sensitive-recall points over Rule. Against FULL, the stronger quality reference, RAG lowered inference cost while sacrificing some evidence-grounded correctness, and the tested agent and routing policies did not earn their complexity. NDATrace is therefore a bounded reviewer aid whose remaining question is whether people can verify its findings more efficiently without losing accuracy.

References

- [1] LegalOn Technologies and In-House Connect, “2025 State of Contracting Survey,” 15 January 2025 (vendor research, n=286). legalontech.com/press-releases/2025-survey
- [2] Y. Koreeda and C. D. Manning, “ContractNLI: A Dataset for Document-level Natural Language Inference for Contracts,” Findings of EMNLP 2021, pp. 1907–1919. aclanthology.org/2021.findings-emnlp.164
- [3] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2026, published 3 August 2026. genai.owasp.org/resource/owasp-genai-llm-top-10-2026